

Stoquify Agent Governance Evidence Capture Runbook

Date: 2026-07-25

Scope: Agent Runtime Phase 2A product/security approval and owner evidence

Local database identities accepted: No

Activation authority: None

Phase 3 authority: None

Purpose

This runbook defines the provider-neutral contract for capturing real product approval, independent security approval, and six-responsibility owner coverage from an authoritative identity and governance system.

It specifically prevents Stoquify's local E2E, seed, fixture, test, or demo users from being promoted into release evidence.

The collector proves that:

- invalid authentication is rejected;
- the authority is available over query-free HTTPS;
- its attestation is no older than 24 hours;
- the attestation is bound to the exact package, release version, commit, artifact, manifest, and evidence bundle;
- product and security approvers are real, current, and distinct;
- all six owner responsibilities have real primary and backup identities;
- every owner accepted the runbook and has current coverage plus an escalation reference;
- the sanitized capture is SHA-256 bound;
- only `governance`, `approvals`, and `owners` can be changed.

The collector cannot change release identity, CI evidence, scheduler evidence, alert evidence, credential rotation, declared status, or activation.

Required Configuration

Configure these values through the deployment configuration and secret systems. Do not place real values in source control.

```
STOQUIFY_AGENT_GOVERNANCE_EVIDENCE_URL=https://<authority-host>/<path>
STOQUIFY_AGENT_GOVERNANCE_EVIDENCE_SECRET=<managed-secret-minimum-32-characters>
STOQUIFY_AGENT_RELEASE_ENVIRONMENT=internal_pilot
STOQUIFY_AGENT_GOVERNANCE_EVIDENCE_TIMEOUT_MS=20000
```

The authority URL must:

- use HTTPS outside local development;
- contain no embedded username, password, query string, or fragment;
- expose `GET` with bearer authentication;
- return `401` for an invalid bearer value;
- return only the sanitized contract below for an authorized request.

Authority Contract

```
{
  "ok": true,
  "data": {
    "ready": true,
    "environment": "internal_pilot",
    "sourceSystemReference": "identity-governance://stoquify/internal-pilot",
    "attestationReference": "attestation://agent-runtime/governance/release-1",
    "attestationDigest": "sha256:<64-hex-characters>",
    "attestedAt": "2026-07-25T13:25:00.000Z",
    "releaseBinding": {
      "packageId": "<package-id>",
      "releaseVersion": "<release-version>",
      "commitSha": "<40-or-64-hex-characters>",
      "artifactDigest": "sha256:<64-hex-characters>",
      "manifestHash": "sha256:<64-hex-characters>",
      "evidenceBundleHash": "sha256:<64-hex-characters>"
    },
    "approvals": {
      "product": {
        "decision": "APPROVED",
        "actorDirectoryId": "directory://person/<product-approver>",
        "approvalReference": "approval://product/<release>",
        "decidedAt": "2026-07-25T12:45:00.000Z",
        "expiresAt": "2026-07-25T18:00:00.000Z",
        "manifestHash": "sha256:<64-hex-characters>",
        "artifactDigest": "sha256:<64-hex-characters>",
        "evidenceBundleHash": "sha256:<64-hex-characters>"
      },
      "security": {
        "decision": "APPROVED",
        "actorDirectoryId": "directory://person/<security-approver>",
        "approvalReference": "approval://security/<release>",
        "decidedAt": "2026-07-25T12:50:00.000Z",
        "expiresAt": "2026-07-25T18:00:00.000Z",
        "manifestHash": "sha256:<64-hex-characters>",
        "artifactDigest": "sha256:<64-hex-characters>",
        "evidenceBundleHash": "sha256:<64-hex-characters>"
      }
    },
    "owners": [
      {
        "role": "ROLLOUT",
        "primaryDirectoryId": "directory://person/<primary>",
        "backupDirectoryId": "directory://person/<backup>",
        "acceptedRunbookVersion": "agent-pilot-runbook-v1",
        "acceptedAt": "2026-07-25T12:30:00.000Z",
        "coverageStartsAt": "2026-07-25T12:00:00.000Z",
        "coverageEndsAt": "2026-07-25T18:00:00.000Z",
        "escalationReference": "evidence://owners/rollout/<release>"
      }
    ]
  }
}
```

```
}  
}
```

The owners array must contain exactly these responsibilities:

- ROLLOUT
- ROLLBACK
- SUPPORT
- PILOT
- SECURITY_INCIDENT
- ON_CALL_BACKUP

Trust Requirements

The authority must be independently administered and must derive identities from the organization's real directory or identity-governance service.

The following are inadmissible:

- local Prisma user IDs;
- browser-test users;
- seed or fixture identities;
- self-declared names without a directory reference;
- copied screenshots without an immutable evidence reference;
- an approval created by the same actor for both product and security;
- a primary owner reused as that responsibility's backup.

Identity references containing `e2e`, `test`, `seed`, `fixture`, or `demo` are rejected.

Capture Procedure

1. Freeze the inactive `PILOT_CERTIFIED` package and exact release identity.
2. Publish the immutable commit, artifact, manifest, and evidence-bundle hashes to the authority.
3. Have the product approver review and approve the frozen release.
4. Have a distinct security approver independently review and approve it.
5. Assign primary and backup identities for all six owner responsibilities.
6. Have every owner accept the current pilot runbook and coverage window.
7. Generate the authority attestation and immutable reference.
8. Expose only the sanitized authority contract.
9. Run:

```
npm run agent:governance:evidence:report
```

10. Inspect the generated JSON and Markdown under `what-next/agents-runtime/`.
11. Apply a ready capture:

```
npm run agent:governance:evidence:apply
```

12. Re-run:

```
npm run agent:operational-release:gate
```

Fail-Closed Rules

The collector refuses to update the register when:

- the endpoint is missing, non-HTTPS, query-bearing, unavailable, oversized, or malformed;
- invalid authentication does not return `401` ;
- the authority reports another environment;
- the attestation is missing, malformed, future-dated, or older than 24 hours;
- the release binding is incomplete or differs from the operational register;
- the package is not inactive and `PILOT_CERTIFIED` ;
- an approval is missing, expired, synthetic, unbound, or not `APPROVED` ;
- product and security approvers are the same;
- an owner responsibility is missing, duplicated, unexpected, expired, or synthetic;
- a primary and backup identity are the same;
- activation is requested, authorized, or recorded.

Retained Evidence

The collector retains:

- value-free authority, attestation, approval, directory, and escalation references;
- the frozen release binding;
- approval and coverage timestamps;
- a SHA-256 hash of the sanitized capture;
- invalid-auth and environment-match outcomes.

It does not retain:

- bearer values or authorization headers;
- raw authority responses;
- directory exports;
- personal contact details;
- passwords, tokens, or signed URLs;
- local database user IDs;
- tenant or business data.

Current Preflight

The repository preflight was executed without external authority configuration and correctly returned:

```
{
  "ok": false,
  "code": "GOVERNANCE_EVIDENCE_URL_MISSING",
  "localDatabaseIdentitiesAccepted": false,
  "secretValuesPrinted": false
}
```

No identity, approval, owner, or operational register value was fabricated or updated.